

THE FORENSICS WAY

ISSUE 30

FORENSICS AWARENESS THIS WEEK

TUESDAY, AUGUST 25, 2026

FRONT PAGE

NATION-STATE

Job Offer, Zero-Day, Backdoor: Lazarus Exploits an Unpatched Windows Driver Flaw to Plant a New Implant Called Troy

Researchers this week detailed an Operation Dream Job wave in which North Korea's Lazarus Group used fake job-offer lures against employees at defense and aerospace firms in France, Germany, Brazil, and India, then escalated privileges through a previously unknown flaw in the Windows Ancillary Function Driver (AFD.sys), tracked as CVE-2026-68820. The exploit chain delivered ForestTiger, a loader Lazarus has used before, alongside a newly identified backdoor called Troy — the group's first documented use of this implant.

AFD.sys mediates nearly all Winsock socket operations, so a privilege-escalation bug there hands an attacker kernel-level reach from a low-privileged foothold with no user interaction beyond opening the initial lure document. Forensic priority: hunt for anomalous AFD.sys IOCTL call patterns and unexpected privilege transitions in kernel event logs, capture memory before remediation since Troy's persistence mechanism is not yet fully cataloged, and treat any defense-sector employee who received an unsolicited recruiter contact in the past month as a potential initial-access vector requiring inbox and endpoint review.

SUPPLY CHAIN

Two Hours to Patch Zero: A Typosquatted Rust Crate Turned 245 Million Downloads Into a Build-Time Backdoor

On August 20, an attacker published malicious versions of three popular Rust crates — arrayref, internment, and append-only-vec, together downloaded roughly 245 million times — each carrying a single added manifest line pulling in proc-macro1, a typosquat of the ubiquitous proc-macro2 crate. Because proc-macro1's build script downloaded and executed a remote payload during compilation, simply building a project that resolved the dependency was enough to run the malware; nothing in the crates

Threat Bulletin

CRITICAL

CVE-2026-65400

Apple macOS — an improper-authentication flaw in Screen Sharing lets a remote attacker bypass credential checks and gain interactive access to a target Mac; CVSS 9.8. Added to CISA KEV on August 18. *Forensic Note:* Review Screen Sharing (VNC/ARD) connection logs for sessions from unrecognized source IPs, check com.apple.screensharing launch daemon activity, and patch to the current macOS security update immediately — no workaround exists for internet-facing hosts.

ACTIVE EXPLOIT

CVE-2026-8037

Progress Kemp LoadMaster — a flaw in the load balancer's management interface allows unauthenticated remote command execution. CISA logged 792 exploit attempts across 65 source IPs over 41 days before the KEV addition. *Forensic Note:* Inventory internet-facing LoadMaster management interfaces, review appliance access logs for the attempt window, and treat any LoadMaster reachable from the open internet as compromised until artifact review proves otherwise.

MALWARE SPOTLIGHT

Amnesia Stealer — The macOS Malware That Watches You Work

Amnesia Stealer is a new macOS credential and cryptocurrency thief that pulls data from 16 Chromium-based browsers, iCloud Keychain, and

themselves had to be imported or called. The Rust Security Response Team pulled all three packages within 86 to 107 minutes of the first report, and researchers have since linked the publishing infrastructure to North Korea-linked group UNC1069.

The attack is a build-time variant of the same trust exploitation seen in npm and PyPI incidents, but compiled-language ecosystems make detection harder — a backdoored build script leaves no trace in the resulting binary for static analysis to catch after the fact. Forensic priority: audit Cargo.lock files for the affected version strings (arrayref 0.3.10, internment 0.8.7, append-only-vec 0.1.9) and for any dependency on proc-macro1, inspect CI/CD build logs from August 20 for outbound connections during compilation, and rebuild from clean lockfiles on any host that resolved the poisoned dependency tree that day.

wallet applications — standard stealer territory. Its distinguishing feature is a built-in Chrome DevTools Protocol client: once a browser session is compromised, the operator receives a live screencast running at roughly 3 frames per second and can drive the authenticated session with a full input set, turning a credential theft tool into an interactive session-hijacking platform. *Forensic Note:* Hunt unexpected processes holding open CDP debug ports (typically 9222) on macOS endpoints, review Keychain access logs for bulk enumeration events, and treat any authenticated banking or SSO session active during a suspected infection window as fully compromised, not merely "credentials exposed."

THE FORENSICS WAY

HISTORICAL ARCHIVES

HISTORY OF DIGITAL INVESTIGATION

TUESDAY, AUGUST 25, 2026

CASE STUDIES: HISTORICAL GRID

DUQU (2011)

The Spy Built From Stuxnet's Bones: How a Word Document Zero-Day Turned Industrial Espionage Into Reconnaissance-as-a-Service

In September 2011, researchers at Hungary's CrySyS Lab uncovered Duqu, an espionage tool sharing significant source code with Stuxnet but built for information-gathering rather than sabotage — it arrived via a Microsoft Word document exploiting an unpatched kernel font-parsing zero-day, then quietly harvested keystrokes, system data, and design documents from industrial manufacturers to prepare future

THE XZ UTILS BACKDOOR (2024)

The Two-Year Con: How a Patient Maintainer Takeover Nearly Backdoored SSH Across Every Major Linux Distribution

In March 2024, Microsoft engineer Andres Freund noticed SSH logins were consuming slightly more CPU than expected and taking a fraction of a second longer — an anomaly he chased into a multi-year social-engineering operation in which a persona named "Jia Tan" had spent two years building trust as a co-maintainer of xz Utils before slipping an obfuscated backdoor into the library's build

attacks. Its shared codebase with Stuxnet became one of the earliest cases where malware genealogy — comparing code structure and driver signing artifacts across samples — let investigators link a new campaign to an established, state-linked toolkit. It is a natural ancestor to this week's Troy backdoor: a fresh implant riding a fresh Windows zero-day, deployed by the same discipline of patient, targeted espionage.

scripts, positioned to compromise OpenSSH on affected distributions. The backdoor lived in autoconf test files and build-time binary blobs rather than the readable source, precisely so that code review would never catch it — the same build-time blind spot this week's Rust crates attack exploited, just compressed from years of patience into an 87-minute smash-and-grab.

THE CTX PYPI HIJACK (2022)

The Theft That Ran at "pip install": How a Hijacked Maintainer Account Turned Setup Scripts Into an Exfiltration Channel

In May 2022, researchers discovered that the popular PyPI package `ctx` had been hijacked through a compromised maintainer account, with a malicious `setup.py` silently exfiltrating environment variables — AWS keys, API tokens, and other secrets — to an attacker-controlled endpoint the instant `pip install` ran; a companion attack against the PHP package `phpass` used the identical technique. Because the theft executed during installation rather than at import or runtime, static scanners and casual code review missed it entirely, and only anomalous outbound traffic during a routine build gave it away.

FLAME (2012)

Too Sophisticated to Hide: How the Most Complex Cyberespionage Tool Ever Found Was Uncovered While Investigating Something Else Entirely

Kaspersky researchers stumbled onto Flame in May 2012 while investigating an unrelated data-wiping incident at Iranian oil facilities — and found a 20-megabyte espionage platform so environmentally precise it fingerprinted each target machine, activated modules only under exact matching conditions, and could remotely trigger its own suicide command to erase all trace of itself if a target didn't match. That same target-specific precision was the tell: its bloated size and unusual Lua-scripted architecture behaved so strangely outside its intended context that analysts caught it almost by accident.

TOOLS OF THE TRADE

OPEN SOURCE

cargo-audit

RUSTSEC TEAM — V0.21

Scans Cargo.lock against the RustSec Advisory Database for known-vulnerable and yanked crate versions. Run it against any lockfile touched on August 20 to catch arrayref, internment, append-only-vec, or a stray proc-macro1 dependency before a rebuild

OPEN SOURCE

capa

MANDIANT — V9.X

Automated capability detection for binaries and memory images, mapping code behavior to MITRE ATT&CK without manual reverse engineering. Point it at recovered Troy samples to rapidly triage the new Lazarus implant's capabilities — persistence, C2, and privilege-

COMMERCIAL

Cellebrite Inspector

CELLEBRITE — V4.X

Endpoint forensic acquisition and analysis for Mac and Windows workstations. Well suited to Amnesia Stealer response: image a suspected Mac, reconstruct Keychain access timelines, and correlate CDP debug-port activity against browser session logs without

UTILITY / SCRIPT

BlockBlock

OBJECTIVE-SEE — V2.X

Free macOS persistence monitor that alerts in real time whenever something installs a launch agent, daemon, or login item. Deployed proactively, it would flag the exact persistence mechanism Amnesia Stealer needs to survive reboot — turning a live-session hijack into a

resurrects this week's build-time backdoor.

escalation logic — ahead of a full manual disassembly.

disrupting a live investigation.

caught-on-install event instead.

PRIORITY CVE ADVISORIES

ARCHIVE ALERT

CVE-2026-59310 (VMWARE VCENTER)

Unauthenticated Syslog server path traversal to RCE; CVSS 9.8. A suspected APT hit 360-plus victim IPs across 47 countries within five days, deploying reverse_ssh and Babuk-derived ransomware as a distraction. CISA KEV. *Forensic Note:* Confirm patching to 9.1.0.0300 or later and hunt lingering cron-based persistence even on already-patched hosts.

ARCHIVE ALERT

CVE-2026-55040 (MICROSOFT SHAREPOINT)

Weak JWT validation accepts alg:none tokens, letting an attacker who knows a target's Windows SID forge an admin session; CVSS 9.1. Exploited within hours of a public PoC. CISA KEV. *Forensic Note:* Review IIS/ULS logs for forged admin sessions and confirm the July patch is applied everywhere.

RECENT MALWARE WATCH

ARCHIVE: AUGUST 18, 2026

REVERSE_SSH — THE OPEN-SOURCE BACKDOOR RIDING VCENTER'S COATTAILS

A legitimate open-source Go SSH tool dropped via malicious cron job after vCenter path-traversal access, giving operators a durable, signature-evading shell back into the environment. Hunt unexpected reverse_ssh binaries and unauthorized cron/systemd entries.

ARCHIVE: AUGUST 11, 2026

NOVA RANSOMWARE — THE RUST ENCRYPTOR THAT BLINDS DEFENDER FIRST

A 64-bit Rust encryptor that reconfigures Microsoft Defender, kills security services, and deletes Volume Shadow Copies before encrypting with XChaCha20-Poly1305 and RSA-2048. Hunt Defender configuration-change events and mass service termination as an early-warning pair.